

Personuppgiftsbiträdesavtal (PUB) — pilot CVmatchen

Helsingborgs stad, Arbetsmarknadsförvaltningen (org.nr 212000-1157), enheten Ungdoms-/Kompetensarena — nedan **Personuppgiftsansvarig (PUA)**

och

PathfinderAI (enskild firma, innehavare Oliver Pettersson, org.nr [FYLLS I]), genom tjänsten **CVmatchen** — nedan **Personuppgiftsbiträde (PUB)**

Avtalsdatum: [FYLLS I] · Pilotperiod: **3 månader från driftsättning** Version: 1.0 (pilot)

Två parter — två underskrifter. Detta avtal tecknas mellan kommunen och PathfinderAI. För kommunen undertecknar en behörig företrädare (t.ex. verksamhets-/enhetschef) — **inte** Oliver Pettersson i sin roll som anställd SYV. Oliver undertecknar enbart för PathfinderAI. Beslutet att genomföra piloten fattas och diarieförs av kommunen oberoende av Oliver (jävshantering enligt förvaltningslagen; bisysslan är prövad och godkänd av HR genom undertecknat beslut).

Företagsform: PathfinderAI drivs i dag som enskild firma. Registrering av aktiebolag planeras; avtalspart justeras till bolaget om/när det är registrerat.

1. Bakgrund och omfattning

Kommunen genomför en tidsbegränsad, kostnadsfri pilot av CVmatchen inom Ungdoms-/Kompetensarena. Piloten omfattar cirka **20–40 deltagare** och **3–4 handläggare**. Syftet är att pröva verktyget i skarp verksamhet och ta fram beslutsunderlag inför eventuellt fortsatt samarbete.

PathfinderAI behandlar personuppgifter enbart för kommunens räkning enligt detta avtal och dess bilagor.

2. Instruktioner

PUB behandlar personuppgifter endast enligt PUA:s dokumenterade instruktioner. PUB informerar PUA om en instruktion bedöms strida mot GDPR.

3. Säkerhetsåtgärder

PUB vidtar lämpliga tekniska och organisatoriska åtgärder (Bilaga B).

4. Underbiträden

Generellt förhandsgodkännande enligt Bilaga C. PUB underrättar PUA minst 30 dagar före förändring; PUA har invändningsrätt. Samtliga underbiträden behandlar data inom EU/EES.

5. Tredjelandsoverföring

Ingen överföring utanför EU/EES sker. Kräver annars PUA:s uttryckliga skriftliga samtycke.

6. Tystnadsplikt

Alla som behandlar personuppgifterna omfattas av sekretess/tystnadsplikt.

7. Bistånd till PUA

PUB bistår med registrerades rättigheter (art. 12–22) och med skyldigheter enligt art. 32–36. I tjänsten finns för registrerade: dataexport (art. 15 & 20), radering av konto (art. 17) och återkalleligt AI-samtycke (art. 7.3).

8. Personuppgiftsincident

PUB informerar PUA utan onödigt dröjsmål, senast inom **24 timmar** från upptäckt, med incidentens art, berörda kategorier/antal, konsekvenser och åtgärder. PUB bistår vid ev. anmälan till IMY.

9. Granskning

PUA har rätt till dokumentation samt på plats-revision (14 dagars varsel).

10. Återlämning/radering vid avslut

Vid pilotens slut raderas eller återlämnas samtliga personuppgifter i öppet format enligt PUA:s val, med skriftlig bekräftelse.

11. Ansvar och avtalstid

Avtalet gäller under pilotperioden. Ansvarsbegränsning: **[fylls i]**; gäller ej vid uppsåt eller grov oaktsamhet. Tvist löses i svensk allmän domstol, Helsingborgs tingsrätt som första instans.

Underskrifter

För Helsingborgs stad, Arbetsmarknadsförvaltningen (Personuppgiftsansvarig):

Namn: ____ Befattning: ____

Datum: __ Underskrift: ____

För PathfinderAI (Personuppgiftsbiträde):

Namn: Oliver Pettersson Befattning: Innehavare

Datum: __ Underskrift: ____

BILAGA A — Behandlingen

- **Ändamål:** CV-skapande, jobbmatchning, intervjuträning och uppföljning inom kommunens arbetsmarknadsverksamhet (Ungdoms-/Kompetensarena).
- **Varaktighet:** pilot 3 månader från driftsättning.
- **Registrerade:** ca 20–40 deltagare + 3–4 handläggare.
- **Kategorier av uppgifter:** namn, kontakt (e-post/telefon), CV-innehåll (erfarenhet, utbildning, kompetenser, körkort, certifikat, ev. profilbild), aktivitetsdata, AI-konversationer (intervjuträning, pseudonymiserade).
- **Inga särskilda kategorier (art. 9)** behandlas avsiktligt; deltagaren varnas i fritextfält mot att skriva in hälsa/ursprung m.m.

BILAGA B — Säkerhetsåtgärder

Tekniska: TLS 1.3 (HSTS), OTP-inloggning för deltagare + Microsoft OAuth för handläggare, HMAC-signerade sessionstokens, Row-Level Security, multi-tenant-isolation, kryptering at rest (AES-256), dagliga säkerhetskopior (7 dagars retention), Sentry-övervakning, PII-maskering i loggar. AI-inferens via AWS Bedrock i EU (Frankfurt) — CV-data lagras inte efter anropet och används inte för modellträning. **Organisatoriska:** privat kodrepo med branch-protection, inga produktionsdata i utveckling, incidentrutin med 24h-frist.

BILAGA C — Underbiträden

Underbiträde	Tjänst	Behandlingsregion
Vercel	Hosting + serverless	Stockholm (EU)
Supabase	Databas + auth	Frankfurt (EU)
AWS Bedrock	AI-inferens	Frankfurt (EU)
Resend	Transaktionsmejl	EU
Sentry	Felövervakning (ej PII)	EU
Microsoft	Inloggning personal	EU

Bör granskas av kommunens dataskyddsombud och jurist innan undertecknande. DPIA (art. 35) tas fram och godkänns av DSO före driftsättning med skarpa personuppgifter.